

Analyze malicious .doc file

By Patrick Ofori-Sampong

Scenario:

Malware analysis on a malicious doc file

Objectives:

Determine the type of exploit executed when the malicious document runs on the victim machine.

Identify the relevant CVE code associated with the exploit.

Discover the name of the malicious software downloaded from the internet as a result of the file execution.

Extract the IP address and port information the malware communicates with.

Identify the executable file name dropped to disk after execution.

Challenge 1:

What type of exploit is running as a result of the relevant file running on the victim machine?

Uploaded the malicious .doc sample to VirusTotal for analysis.

Observed that 41 security vendors flagged the file as malicious. Based on the detection results, the file attempts to exploit a known Microsoft Office vulnerability CVE-2017-11882.

The screenshot shows the VirusTotal interface for a file named 'factura.doc'. A red circle with the number '41' indicates that 41 security vendors and 2 sandboxes have flagged the file as malicious. The file's SHA-256 hash is '5a31c72293a72920d70205d0236691adcea2c57c2716458ce118a5c8a9d4913'. The file size is 11.46 KB, and it was last analyzed 5 days ago. The file type is 'RTF'. The detection results are categorized into 'Crowdsourced YARA rules', 'Crowdsourced Sigma Rules', 'Dynamic Analysis Sandbox Detections', 'Popular threat label' (Trojan.exploit), 'Threat categories' (trojan), and 'Family labels' (exploit). The 'Security vendors' analysis section shows a table of detections from various vendors.

Vendor	Detection
AhnLab-V3	RTFMallform-A.Gen
Avast	Trojan.Generic.D3DF13D8
AVG	OLE/CVE-2017-11882 [Exploit]
BitDefender	Trojan.GenericKD.64951256
Cyren	Malicious (score: 99)
DrWeb	Exploit.ShellCode.69
Antiy-AVL	Trojan(Exploit)OLE2.CVE-2017-11882
Avast	OLE/CVE-2017-11882 [Exploit]
Avira (no cloud)	HEUR/Trojan.Mallform
ClamAV	RTF.Exploit.CVE_2017_11882-6584355-1

This type of exploit is rtf.exploit

The screenshot shows the ClamAV detection results for the file. A red circle with an exclamation mark indicates a detection. The detection is labeled 'Rtf.Exploit.CVE_2017_11882-6584355-1'.

This vulnerability is associated with RTF exploit, commonly used to execute malicious code when the victim opens the file.

Further inspection revealed that the document makes contact with an HTTP C2 server to download a secondary payload.

The screenshot shows the NetworkMiner analysis results for the file. It displays 'HTTP Requests' and 'DNS Resolutions'.

HTTP Requests

Request
http://seed-bc.com/juop4/plwrmklo/rbn/jan2.exe

DNS Resolutions

Resolution
dns.msftncsi.com
seed-bc.com
185.36.74.48

IP Traffic

Traffic
185.36.74.48:80 (TCP)

Upon execution, the file drops an executable named aro.exe to the disk.

Files Written

🔒 %APPDATA%\aro.exe
🔒 C:\Users\user\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.Word\~WRF[B6D72AD4-D47A-4257-A7A2-E083FE08FB27].tmp
🔒 C:\Users\user\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.Word\~WRS[3CEFA7C-6B84-4C23-893B-2F0B89A09FAB].tmp
🔒 C:\Users\user\AppData\Local\Microsoft\Windows\Temporary Internet Files\Content.Word\~WRS[D3258957-8A0B-4520-8581-0F9F1B59D328].tmp
🔒 C:\Users\user\AppData\Local\Temp\397644821e254f26bc27783c451719f1.doc
🔒 C:\Users\user\AppData\Local\Temp\~\$7644821e254f26bc27783c451719f1.doc
🔒 C:\Users\user\AppData\Roaming\Microsoft\Office\Word12.pip
🔒 C:\Users\user\AppData\Roaming\Microsoft\Templates\~\$Normal.dotm
🔒 C:\Users\user\AppData\Roaming\Microsoft\UProof\CUSTOM.DIC
🔒 c:\users\rdhj\ocnfevxlappdata\roaming\aro.exe

Verified that the dropped file (aro.exe) was also flagged as malicious by 55 vendors on VirusTotal.

5df85a1c9a3b450d9aa14d3ea0aebac9db88623004e5ed7b40e7ab3b17cd31

55 security vendors and 1 sandbox flagged this file as malicious

Size: 3.44 MB | Last Analysis Date: 3 hours ago

peexe | assembly | runtime-modules | detect-debug-environment | spreader | direct-cpu-clock-access

Community Score: 55 / 67

Dynamic Analysis Sandbox Detections

The sandbox Zorbox flags this file as: MALWARE TROJAN EVADER RAT

Popular threat label: trojan.msl/bulz | Threat categories: trojan | Family labels: msl, bulz, nanobot

Security vendors' analysis

Vendor	Detection	Vendor	Detection
AhnLab-V3	Trojan.Win32.AgentTesta.R368390	Alibaba	Backdoor.MSL.AgentTesta.d12f5e3
ALYac	Gen.Variant.Bulz.375833	Antiy-AVL	Trojan(Backdoor)MSL.NanoBot
Arcabit	Trojan.Bulz.D5BC19	Avast	Win32:MalwareX-gen [Trj]
AVG	Win32:MalwareX-gen [Trj]	Avira (no cloud)	HEUR:GEN.1305624

Answer: rt.exploit

Challenge 2:

What is the relevant Exploit CVE code obtained as a result of the analysis?

Answer: CVE-2017-11882

Challenge 3:

What is the name of the malicious software downloaded from the internet as a result of the file running?

Answer: jan2.exe

Challenge 4:

What is the ip address and port information it communicates with?

Answer: 185.36.74.48:80

Challenge 5:

What is the exe name it drops to disk after it runs?

Answer: aro.exe